

EISI M3.4 - COBIT - Fiche de synthèse

Contrôle des Objectifs pour l'Information et les Technologies

1. Introduction au COBIT

COBIT (Control Objectives for Information and Related Technologies) est un référentiel de gouvernance et de gestion des systèmes d'information, développé initialement par l'**ISACA** (Information Systems Audit and Control Association). Il vise à **assurer une gouvernance efficace des technologies de l'information en alignant les objectifs IT avec les objectifs stratégiques de l'entreprise**.

2. Historique et versions

Version	Année	Caractéristiques principales
COBIT 1	1996	Référentiel de contrôle informatique initial.
COBIT 2	1998	Améliorations des objectifs de contrôle.
COBIT 3	2000	Introduction de la gestion des processus.
COBIT 4.0	2005	Alignement avec d'autres référentiels comme ITIL et ISO/IEC 27001.
COBIT 4.1	2007	Modèle d'évaluation de maturité renforcé.
COBIT 5	2012	Fusion avec Val IT et Risk IT. Intégration complète des dimensions de gouvernance.
COBIT 2019	2018-2019	Approche modulaire, plus agile, intégration des nouvelles réalités numériques.

3. Objectifs du référentiel

- Fournir un cadre de gouvernance et de gestion des technologies de l'information
- Favoriser la création de valeur par l'IT
- Aider les parties prenantes à équilibrer les bénéfices, les risques et les ressources
- Proposer des bonnes pratiques, des indicateurs de performance et des modèles d'évaluation.

4. Les composants clés de COBIT 2019

Les 6 principes de gouvernance :

1. Satisfaire aux besoins des parties prenantes
2. Couvrir l'ensemble de l'entreprise
3. Appliquer un cadre unique intégré
4. Permettre une approche holistique
5. Distinguer gouvernance et gestion
6. Adapter au contexte de l'entreprise

Les facteurs de conception

Ils permettent d'adapter COBIT à l'organisation (taille, appétence au risque, maturité numérique...).

Les objectifs de gouvernance et de gestion

COBIT 2019 identifie **40 objectifs** répartis selon deux domaines :

- **Gouvernance** (5 objectifs, domaine "EDM" – Evaluate, Direct and Monitor)
- **Gestion** (35 objectifs, répartis dans les domaines : Align, Plan and Organize ; Build, Acquire and Implement ; Deliver, Service and Support ; Monitor, Evaluate and Assess)

5. Liste des 40 objectifs de la dernière version

Domaine : Évaluer, Diriger et Surveiller (EDM) – Gouvernance

1. EDM01 : Assurer la mise en place et la maintenance du cadre de gouvernance
Mettre en place et maintenir un cadre de gouvernance efficace
2. EDM02 : Assurer la livraison des bénéfices
Garantir que l'organisation obtient les bénéfices attendus de ses investissements
3. EDM03 : Assurer l'optimisation des risques
Optimiser la gestion des risques pour soutenir les objectifs de l'organisation
4. EDM04 : Assurer l'optimisation des ressources
Optimiser l'utilisation des ressources pour atteindre les objectifs.
5. EDM05 : Assurer l'engagement des parties prenantes
Engager efficacement toutes les parties prenantes dans la gouvernance

Domaine : Aligner, Planifier et Organiser (APO) – Management

6. APO01 : Gérer le cadre de gestion de l'information et de la technologie (I&T)
Définir le cadre de gestion I&T
7. APO02 : Gérer la stratégie
Définir la stratégie I&T alignée sur la stratégie d'entreprise
8. APO03 : Gérer l'architecture d'entreprise
Développer et maintenir l'architecture d'entreprise
9. APO04 : Gérer l'innovation
Promouvoir et gérer l'innovation
10. APO05 : Gérer le portefeuille
Gérer le portefeuille des programmes et services I&T
11. APO06 : Gérer le budget et les coûts
Planifier et contrôler le budget et les coûts I&T
12. APO07 : Gérer les ressources humaines
Gérer les ressources humaines nécessaires à la gestion I&T
13. APO08 : Gérer les relations
Gérer les relations avec les parties prenantes
14. APO09 : Gérer les accords de service
Gérer les accords de service avec les fournisseurs
15. APO10 : Gérer les fournisseurs
Gérer les relations avec les fournisseurs
16. APO11 : Gérer la qualité
Assurer la qualité des services et produits I&T
17. APO12 : Gérer les risques
Identifier, évaluer et gérer les risques I&T
18. APO13 : Gérer la sécurité
Assurer la sécurité de l'information et des systèmes

19. APO14 : Gérer les données
Gérer le cycle de vie des données

Domaine : Construire, Acquérir et Implanter (BAI) – Management

20. BAI01 : Gérer les programmes et projets
Gérer les programmes et projets I&T
21. BAI02 : Gérer la définition des exigences
Définir et gérer les exigences métiers et techniques
22. BAI03 : Gérer l'identification et la construction des solutions
Identifier et concevoir les solutions I&T
23. BAI04 : Gérer la disponibilité et la capacité
Assurer la disponibilité et la capacité des services I&T
24. BAI05 : Gérer l'implémentation des changements organisationnels
Gérer les changements organisationnels liés aux projets I&T
25. BAI06 : Gérer les changements
Gérer les changements apportés aux systèmes et services
26. BAI07 : Gérer l'acceptation et la transition
Gérer l'acceptation et la transition des solutions dans l'environnement de production
27. BAI08 : Gérer les connaissances
Gérer les connaissances liées à l'information et à la technologie
28. BAI09 : Gérer les actifs
Gérer le cycle de vie des actifs I&T
29. BAI10 : Gérer la configuration
Gérer la configuration des systèmes et services

Domaine : Fournir, Servir et Supporter (DSS) – Management

30. DSS01 : Gérer les opérations
Gérer les opérations quotidiennes des systèmes et services I&T

- 31. DSS02 : Gérer les demandes et incidents de service
Gérer les demandes et incidents de service
- 32. DSS03 : Gérer les problèmes
Gérer la résolution des problèmes récurrents
- 33. DSS04 : Gérer la continuité
Assurer la continuité des services I&T
- 34. DSS05 : Gérer les services de sécurité
Gérer les services de sécurité pour protéger les actifs
- 35. DSS06 : Gérer les contrôles des processus métier
Gérer les contrôles intégrés dans les processus métier

Domaine : Surveiller, Évaluer et Estimer (MEA) – Management

- 36. MEA01 : Surveiller, évaluer et estimer la performance et la conformité
Surveiller et évaluer la performance et la conformité des processus I&T
- 37. MEA02 : Surveiller, évaluer et estimer le système de contrôle interne
Surveiller et évaluer le système de contrôle interne
- 38. MEA03 : Surveiller, évaluer et estimer la conformité aux exigences externes
Surveiller la conformité aux exigences réglementaires et externes
- 39. MEA04 : Surveiller, évaluer et estimer la gestion des risques
Surveiller et évaluer la gestion des risques I&T
- 40. MEA05 : Surveiller, évaluer et estimer la gouvernance
Surveiller et évaluer l'efficacité de la gouvernance I&T

6. Objectif EDM01 - Assurer la mise en place et la maintenance du cadre de gouvernance

Description générale

EDM01 vise à garantir que l'organisation dispose d'un cadre de gouvernance robuste, adapté à ses besoins et aligné sur ses objectifs stratégiques. Ce cadre est essentiel pour orienter, surveiller et évaluer la gouvernance effective de l'information et des technologies (I&T) au sein de l'organisation

Principales activités

- **Définir le cadre de gouvernance** : Élaborer des principes, des politiques, des procédures et des mécanismes de prise de décision pour la gouvernance de l'I&T;
- **Impliquer les parties prenantes** : Identifier les parties prenantes clés, documenter leurs exigences et s'assurer que le cadre prend en compte leurs attentes et leurs rôles dans la gouvernance;
- **Communiquer et diffuser** : S'assurer que le cadre de gouvernance est bien compris et adopté par toutes les parties concernées dans l'organisation.

Objectifs spécifiques

- **Créer une vision commune** de la gouvernance I&T au sein de l'organisation;
- **Fournir une structure claire** pour la prise de décision et la responsabilisation;
- **Assurer la conformité** avec les exigences réglementaires et les meilleures pratiques;
- **Faciliter l'amélioration continue** de la gouvernance grâce à des mécanismes de suivi et de contrôle.

Résultats attendus

- Un cadre de gouvernance formalisé et documenté;
- Des rôles et responsabilités clairement définis;
- Une prise de décision efficace et transparente;
- Une capacité à s'adapter aux changements et à améliorer en continu la gouvernance de l'I&T.

6. Exemples d'utilisation de COBIT

Une banque souhaite améliorer sa conformité réglementaire (e.g. RGPD). COBIT permet de :

- identifier les processus critiques en matière de gestion des risques (EDM03, APO12).
- mettre en œuvre des KPI et une gouvernance formalisée.

Dans une université, COBIT peut structurer les décisions d'investissement IT en garantissant la valeur générée pour les étudiants et chercheurs (EDM02, APO05).

7. Forces et limites de COBIT

Forces

- Approche globale et flexible.
- Compatible avec d'autres cadres (ITIL, ISO, TOGAF).
- Riche documentation.

Limites

- Complexité initiale pour les novices.
- Nécessite un engagement fort de la direction.

8. Sources pour approfondir (FR & EN)

Documentation officielle et académique

- [ISACA COBIT 2019 Framework](#)